Отчёт о расследовании инцидента информационной безопасности «Сфера Логистикс»

Общая информация

- **Организация**: «Сфера Логистикс».
- **Дата инцидента**: 14 Nov
- **Время обнаружения**: Утро того же дня
- **Инициатор расследования**: отдел информационной безопасности.
- **Цель расследования**: установление факта инцидента ИБ и его последствий.

Описание инцидента

В ночное время зафиксирована серия подозрительных событий, указывающих на возможную компрометацию складской системы учёта (WMS) и несанкционированное проникновение во внутреннюю сеть компании.

Точка начальной компрометации

Обращение к серверу WMS, фишинг рабочей почты, сработало и то и то, поскольку логи нарисованы, логической связности нет

Эскалация привилегий и перемещение внутри сети

Эскалация привилегий через sudo /bin/bash по скачанному скрипту из письма с фишингом.

pc_buh2 (фишинг → root)

(кража учётных данных администратора)

Бастион / компьютер администратора (10.10.40.2)

srv_wms (WMS) → SQL-инъекции → экспорт данных → удаление таблиц

srv_db (БД) → чтение таблиц → экспорт данных

srv_crm (CRM) → просмотр данных

srv_files (файловый сервер) → монтирование → кража файлов

srv_adm (сервер управления) → запуск скриптов → чтение /etc/passwd

Компрометация баз данных и утечка информации

- Таблицы БД: users, orders, clients, payments, accounting, confidential_data.
- Пароли пользователей (из таблицы users, /etc/passwords).
- Платёжные данные (кредитные карты).
- Бухгалтерские и финансовые отчёты.
- Конфиденциальные данные компании.
- Удаление БД

Классификация инцидента

Initial Access	Phishing	T1566
Execution	User Execution	T1204
Persistence	Boot or Logon Autostart	T1547
Privilege Escalation	Abuse Elevation Control Mechanism	T1548
Credential Access	Credential Dumping	T1003
Discovery	Network Service Scanning	T1046

Lateral Movement	Remote Services (SSH)	T1021
Collection	Data from Local System	T1005
Exfiltration	Exfiltration Over C2 Channel	T1041

Последствия

Критические, практически вся система скомпрометирована

Таймлайн инцидента

Зафиксируйте все ключевые события инцидента.

Время	Событие	Компонент	Описание
23:47:20	Accepted password for lobanov from 10.10.40.2	srv_wms (SSH)	Подключение пользователя lobanov (пароль) — учётные данные впоследствии скомпрометированы
23:52:45	Visited internal portal	pc_buh2 (Firefox)	Начало сессии пользователя olga
00:00:10	SELECT * FROM users WHERE 1=1	База данных (WMS)	SQL-инъекция — чтение таблицы users
00:00:25	SELECT * FROM users WHERE 1=1 --	WMS	SQL-инъекция — чтение пользователей
00:10:00	EXPORT TABLE orders TO '/tmp/dump_orders.csv'	База данных	Экспорт таблицы orders

00:10:15	ExportData Table=orders	WMS	Экспорт заказов
00:13:30	Downloaded file invoice_update.pdf.exe	pc_buh2 (Firefox)	Фишинг — скачивание ВПО
00:14:35	File saved: /home/olga/Downloads/invoice_update.pdf.exe	pc_buh2 (kernel)	ВПО сохранено на диск
00:16:45	User executed file invoice_update.pdf.exe	pc_buh2 (kernel)	Запуск ВПО
00:17:50	Process started: invoice_update.pdf.exe pid=1322	pc_buh2 (kernel)	ВПО активно
00:18:55	Connection established to 192.168.10.2:4444	pc_buh2 (kernel)	Установка C2-соединения
00:20:05	Data transfer initiated to 192.168.10.2:4444	pc_buh2 (kernel)	Передача данных на C2 (начало)
00:21:10	sudo /bin/bash	pc_buh2 (sudo)	Повышение привилегий — получение root
00:22:15	session opened for user root	pc_buh2 (sudo)	Сессия root открыта
00:23:20	Elevated privileges: root shell opened	pc_buh2 (kernel)	Root-доступ подтверждён
00:24:25	Root command: netstat -antp	pc_buh2 (bash)	Просмотр сетевых соединений (разведка)
00:25:30	SELECT * FROM users UNION SELECT password	WMS	Кража паролей пользователей
00:27:40	Scanned internal network: 10.10.20.0/24	pc_buh2 (kernel)	Сканирование сети (разведка)

00:28:45	Visited internal CRM: http://10.10.20.12	pc_buh2 (Firefox)	Доступ к CRM
00:29:50	Inbound from 10.10.20.12:80 accepted	pc_buh2 (kernel)	Подтверждение доступа к CRM
00:30:55	Outbound to 10.10.20.11:80 (WMS)	pc_buh2 (kernel)	Доступ к WMS
00:31:00	ssh 10.10.20.15	pc_buh2 (bash)	Попытка SSH к БД (успешна)
00:32:05	SSH connection attempt to 10.10.20.15:22	pc_buh2 (kernel)	SSH-доступ к БД
00:35:20	ExportData Table=clients	WMS	Экспорт клиентов
00:35:20	Downloaded tool: /tmp/exploit.sh from 192.168.10.2	pc_buh2 (bash)	Загрузка эксплойта
00:36:25	Executed /tmp/exploit.sh	pc_buh2 (kernel)	Запуск эксплойта
00:37:30	Network probe to 10.10.20.22:445	pc_buh2 (kernel)	Доступ к файловому серверу
00:38:35	Mounted remote share from 10.10.20.22	pc_buh2 (systemd)	Монтирование сетевой папки
00:39:40	File copy to /tmp/leak.csv from mounted share	pc_buh2 (kernel)	Сбор украденных данных
00:40:45	Exfiltrated data to 192.168.10.2:4444	pc_buh2 (bash)	Эксфильтрация данных
00:41:50	Connection closed to 192.168.10.2:4444	pc_buh2 (kernel)	Завершение передачи данных

00:42:55	session closed for user root	pc_buh2 (sudo)	Завершение root-сессии
00:43:00	Privileges dropped	pc_buh2 (kernel)	Сброс привилегий
00:46:15	DROP TABLE orders --	WMS	Удаление таблицы заказов
00:47:55	DROP TABLE temp_logs --	База данных	Удаление таблицы логов
00:56:05	AccessTable Table=accounting	WMS	Доступ к бухгалтерским данным
00:58:45	SELECT * FROM payments WHERE 1=1	База данных	Чтение платёжных данных
01:00:20	File downloaded: attachment_summary.pdf	pc_buh2 (Firefox)	Кража финансового отчёта (PDF)
01:06:55	ExportData Table=users	WMS	Экспорт пользователей
01:07:55	File downloaded: monthly_summary.csv	pc_buh2 (Firefox)	Кража ежемесячного отчёта (CSV)
01:09:35	EXPORT TABLE users TO '/tmp/leak_users.csv'	База данных	Экспорт пользователей в CSV
01:16:45	SELECT * FROM accounting WHERE 1=1	WMS	Чтение бухгалтерских данных
01:21:30	SELECT * FROM confidential_data WHERE 1=1	База данных	Чтение конфиденциальных данных
01:26:35	AccessTable Table=confidential	WMS	Доступ к конфиденциальным данным

00:10:15	Unusual process started: /tmp/temp_script.sh pid=1567	srv_adm (kernel)	Запуск подозрительного скрипта на сервере управления
00:11:20	Detected outbound connection to external IP 192.168.10.2	srv_adm (systemd)	Установка C2-соединения с srv_adm
00:12:25	Network connection established to 192.168.10.2:4444	srv_adm (kernel)	Подтверждение C2-канала с srv_adm
00:13:30	Process 1567 data transfer initiated	srv_adm (systemd)	Начало передачи данных с srv_adm на C2
00:25:30	Suspicious file access: /etc/passwd by pid=1890	srv_adm (kernel)	Чтение файла /etc/passwd
00:27:40	Process 1890 ran: cat /etc/passwd	srv_adm (kernel)	Кража списка пользователей (выполнено cat /etc/passwd)
00:28:45	sudo: www-data : COMMAND=/bin/cat /etc/passwd	srv_adm (sudo)	Использование sudo для чтения /etc/passwd
00:31:00	Data exfiltration attempt to 192.168.10.2	srv_adm (kernel)	Попытка эксфильтрации данных с srv_adm
00:33:10	Outbound traffic: 1MB to 192.168.10.2:4444	srv_adm (kernel)	Передача 1 МБ данных с srv_adm на C2

Итоговый вердикт

- Веб-сервер надежно защищен, исходя из логов access.log и error.log, были заблокированы практически все возможные виды компрометации данных с помощью инструментов веб-атак(SQL,XSS,Загрузка ВПО, удаленное выполнение кода, скачивание БД). Ip злодея 192.168.10.2(возможно не настоящий)
- На основании логов API поддельные токены и куки на смогли помочь злодею скомпрометировать систему
- WMS скомпрометирован
- На основании логов fw&router прямое подключение не удалось, прямой сетевое доступ невозможен
- Скомпрометирован ПК сотрудника бухгалтерии через фишинг почты

На основании анализа собранных данных можно сделать следующие выводы:

- **Факт инцидента**: подтверждён.
- **Характер событий**: атака.
- **Уровень угрозы**: высокий.

Рекомендации:

Немедленные действия.

- **Изолировать все скомпрометированные узлы**, чтобы остановить распространение и C2- трафик.
- **Заблокировать на межсетевом экране** исходящие и входящие соединения на IP 192.168.10.2
- **Сменить пароли всех пользователей**
- **Восстановить удаленные таблицы** (orders, temp_logs)
- **Убрать старые эндпоинты из сети**
- **Запустить антивирусное сканирование** всех систем или установить AB
- **Доступ по SSH только с бастиона**

ДОЛГОСРОЧНЫЕ МЕРЫ

- **Закрыть уязвимости в WMS** – переписать SQL- запросы с использованием параметризованных вызовов, внедрить строгую валидацию ввода.
- **Внедрить факторную аутентификацию (2FA)**
- **Установить EDR- решения** на все рабочие станции и серверы, настроить централизованный сбор логов (SIEM) с корреляцией событий.
- **Провести обучение сотрудников** по распознаванию фишинговых писем и безопасной работе с вложениями.
- **Принцип минимальных полномочий (sudo не используется рядовыми сотрудниками).**
- **Пересмотреть правила межсетевого экрана** – удалить устаревшие ACL, запретить любые исходящие соединения из серверной зоны без явного разрешения. Семгент DMZ судя по всему не работает, т.к. Был прямой сетевой доступ в WMS.

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.